to receive information electronically.[884] In contrast, five states allow electronic notification without restriction, and two states require only that the institution has an email address for the affected individuals.[885] We expect that for the 11 million potential customers residing in these seven states[886]—that allow electronic notification even to customers who have not explicitly agreed to receiving electronic notification—the final amendments will help ensure that they receive a notice in a format that they are expecting.[887]

Third, all states allow for a substitute notice under certain conditions.[888] Substitute notification requirements vary across states but must generally include an email notification to affected individuals, a notice on the entity's website, and notification to major statewide media.[889] The final amendments do not provide for such substitute notice and instead have the same notice requirements in all cases. We expect that the final amendments will strengthen the benefits of notification by helping ensure that affected individuals are made aware of the relevant information regarding a breach of their sensitive information. Examples of customers who would benefit include customers who: interact infrequently with the covered institution, thereby not visiting the institution's website regularly; who do not consume local or state news sources; or who may be wary or skeptical of receiving such information by email if they have not given their prior informed consent (for example, customers who are used to receiving communications from

---

884 *See supra* footnote 200 and accompanying text.

885 *See supra* footnotes 565 and 566 and accompanying text.

886 *See supra* footnote 767.

887 We acknowledge that the final amendments may result in some customers receiving a notice in a format that they do not prefer. For example, customers could agree to an electronic notice but still receive a notice by mail, which they may be less likely to see or respond to.

888 These conditions often include a certain minimum number of affected individuals to notify and a minimum dollar cost to notify these individuals. *See supra* footnote 569 and accompanying text.

889 *See supra* section IV.C.2.a(2).

the covered institution by mail only or who interact with the covered institution very rarely). In other states, the requirements for substitute notice include fewer elements.[890] We expect that for the customers residing in these states, the final amendments will help ensure that they are made aware of the breach and provided an appropriate notice.

The final amendments require written notification, which may be provided electronically if certain conditions are met, such as if the customer has agreed to receive information electronically.[891] Not all state notification provisions include similar consent conditions for electronic communication.[892] Therefore, the final amendments may result in additional compliance costs in the instances where, prior to the final amendments, the covered institutions would have sent email notices or used substitute notification, but will instead have to obtain customer consent for electronic notification or else send individual notices by mail because their methods of electronic delivery are not consistent with existing Commission guidance on electronic delivery, for example if they have not obtained customer consent to receive electronic communications.[893] However, given the variety of state law conditions and requirements, we expect that most notices being sent already satisfy many of these provisions and we therefore expect that these provisions will result in limited additional costs.[894]

---

890 *See supra* footnote 571 and accompanying text.

891 *See supra* section II.A.3.e. and footnote 200.

892 *See supra* footnote 885 and accompanying text.

893 *Id*. Because some states have conditions for sending an electronic notice that are different from those under the final amendments, we expect that there might be some cases where a covered institution will be required to send a notice by mail when it could have sent an electronic notice under state law. *See supra* footnotes 884 through 888 and accompanying text.

894 An analysis of the notices sent to residents of California and Washington suggests that notices are frequently sent by postal mail. Both states allow for electronic notification if the notice is consistent with the Electronic Signatures in Global and National Commerce Act (15 U.S.C. 7001). Nevertheless, we have found that in California, at least 90% of the notices appear to be sent by mail. The equivalent number is 89% for Washington. We identified the notices sent by mail (as opposed to those sent by email or satisfying other substitute notice requirements) as those including a redacted or mock recipient address, an address for

c. Service Provider Provisions

The final amendments require that a covered institution's incident response program include the establishment, maintenance, and enforcement of written policies and procedures reasonably designed to require oversight, including through due diligence and monitoring, of service providers. Specifically, these written policies and procedures must be reasonably designed to ensure the service providers take appropriate measures to protect against unauthorized access to or use of customer information and provide notification to the covered institution as soon as possible, but no later than 72 hours after becoming aware that a breach in security has occurred resulting in unauthorized access to a customer information system. Upon receipt of such notification, a covered institution must initiate its incident response program.[895] In the final amendments, "service provider" is defined as "any person or entity that receives, maintains, processes, or otherwise is permitted access to customer information through its provision of services directly to a covered institution."[896] Thus, the requirements might affect arrangements with a broad range of entities, including potentially email providers, customer relationship management systems, cloud applications, and other technology vendors.

As modern business processes increasingly rely on service providers,[897] ensuring consistency in regulatory requirements increasingly requires consideration of the functions performed by service providers and how these functions interact with the regulatory regime.[898]

---

a return mail processing center, or an explicit mention such as "Via First-Class Mail." It is possible that notices containing none of these elements are sent by mail, and therefore we expect that the true percentages are likely to be higher than those reported here. *See supra* footnotes 777 and 782 and accompanying text for details on the notice data used for this analysis.

895 *See* final rule 248.30(a)(5)(i).

896 Final rule 248.30(d)(10).

897 *See supra* section IV.C.3.f

898 *See supra* section IV.C.2.a(3).

Ignoring such aspects could incentivize covered institutions to attempt to outsource functions to service providers to avoid the requirements that would apply if the functions were performed in-house. Thus, the service provider requirements will strengthen the benefits of the final amendments by helping ensure that they have similar effects regardless of how a covered institution chooses to implement its business processes (i.e., whether those processes are implemented in-house or outsourced).

Commenters supported the proposal's objective to safeguard customer information in the case where this information rests with service providers.[899] One commenter stated that third-party service providers were specifically a favored attack vector, adding that the Commission's attention to this risk was well-directed.[900] Another commenter stated that it did not disagree that service providers should protect sensitive customer information and be required to provide timely notification of a breach to the covered institution.[901] Another commenter stated that service providers that have access to customer information should be contractually required to take appropriate risk-based measures and diligence designed to protect against unauthorized access to or use of customer information, including notification of a covered institution in the event of certain types of breaches in security.[902] Another commenter recognized and supported the importance of covered institutions having appropriate policies and procedures to manage the cybersecurity and privacy risks posed by service providers that process their customer information.[903]

---

899 *See, e.g.*, EPIC Comment Letter; SIFMA Comment Letter 2.

900 *See* EPIC Comment Letter.

901 *See* IAA Comment Letter 1.

902 *See* SIFMA Comment Letter 2.

903 *See* CAI Comment Letter.

Some commenters criticized the analysis of the proposed service provider provisions.[904] One commenter stated, referring to the proposed service provider written agreement obligation, that the Commission had failed to address the costs in any meaningful way and was thus dismissive of them.[905] Another commenter stated that the Proposing Release included no discussion or estimate of the costs that renegotiating contracts with service providers or hiring new service providers would impose on brokers.[906] In addition, some commenters disagreed with our analysis of specific parts of the requirements, stating that the analysis in the Proposing Release did not identify why a 48-hour reporting period was optimal,[907] or stating that the breadth of the definition of service providers was disproportionate to the benefits and risks presented.[908] In response to these commenters, we have modified this aspect of the amendments, as discussed in greater detail above.[909] These modifications mitigate, but may not eliminate entirely, commenters' concerns regarding the costs associated with the service provider provisions of the proposed amendments. We also have supplemented the economic analysis of the service provider provisions in response to comments as follows. First, we have supplemented the analysis of the potential costs to covered institutions. This includes an analysis of the indirect effects of the final amendments on covered institutions' service providers, and how these effects

---

904 *See, e.g.*, IAA Comment Letter 1; ASA Comment Letter.

905 *See* IAA Comment Letter 1.

906 *See* ASA Comment Letter. In the Proposing Release, we requested data that could help us quantify the costs and benefits that we were unable to quantify. We did not receive data or estimates from commenters that could help us quantify the costs of renegotiating contracts or hiring new service providers. *See* Proposing Release at section III.G, question 110.

907 *See* Microsoft Comment Letter.

908 *See* IAA Comment Letter 1 ("We believe the proposed definition of Service Provider is unrealistically and unnecessarily broad, reaching service providers where there are little or no marginal benefits to their inclusion and the costs (time, money, personnel, etc.) to advisers would be substantial.").

909 *See supra* section II.A.4.

may affect covered institutions and their customers,[910] for example where costs to service providers are passed on to covered institutions, and ultimately to covered institutions' customers,[911] or have negative competitive effects that impact covered institutions.[912] Second, we are providing supplemental analysis specifically on the timeline requirement and the definition of service providers.[913]

The costs to covered institutions of implementing the final amendments will be influenced by the potential burdens on service providers that may result from the amendments. If implementing procedures that satisfy covered institutions' requirements were costless for them, service providers would be likely to agree to implement the requirements without much negotiation and the costs to covered institutions would be minimal. If, instead, such procedures were costly to implement for service providers, more negotiation would be required, which would be costlier for all parties involved. In addition, in this case, the service providers might increase the price of their services, further increasing the costs for covered institutions.[914] We discuss further below the expected indirect effects of the final amendments on service providers and how these effects may affect covered institutions.[915]

However, even if, as in the scenario described above, the cost per service provider turns out to be minimal for covered institutions, the total cost might still become significant for covered institutions that have a large number of service providers. Even in this case, covered

---

910 *See infra* footnotes 928-936 and accompanying text.

911 *See infra* text accompanying footnote 933.

912 *See infra* section IV.E.

913 Additional context for this analysis is provided in section IV.C.3.f.

914 Because we are not aware of any data, and no commenter suggested any data, that could be used to estimate how much service providers will pass through increased costs to covered institutions, we are unable to quantify the magnitude of the potential increased costs for covered institutions.

915 *See infra* text accompanying footnote 927.

institutions will need to devote time and resources to verify that they satisfy the final requirements with respect to each of their service providers. In addition, covered institutions will need to devote time and resources to oversee their service providers throughout their relationship with these service providers.[916] We are unable to quantify these costs, as the range would be too wide to be informative and commenters did not provide any data that would yield an estimation of such a range. The range of costs for covered institutions is likely to be wide given the varied nature of the uses of service providers by financial institutions. For instance, the cost for covered institutions that do not rely on service providers is likely to be minimal. However, for those covered institutions that have more complex arrangements with service providers, the cost would be significantly higher. The cost depends on a large number of factors that vary across covered institutions.[917] For example, the cost would depend on the number of service providers used, the extent to which service providers are used for multiple functions, each service provider's access to relevant customer information, as well as the staffing needs of the covered institutions.

The definition of service provider in the final amendments will affect the costs to covered institutions by determining the number of service providers for which covered institutions will

---

916 *See supra* section II.A.4. For PRA purposes, we have identified certain types of staff who we anticipate would be involved in implementing the rules. *See infra* section V.B. It is possible that those staff members may also be involved in oversight of service providers.

917 In a proposing release pertaining to service providers, the Commission anticipated a range of compliance costs associated with required oversight of service providers by registered investment advisers. For example, in the proposing release, the Commission estimated a range of $44,106.67 - $132,320 in ongoing annual costs per adviser associated with the proposed due diligence requirements (and further costs associated with proposed monitoring requirements and other aspects of the proposed rule). We do not believe those ranges of cost estimates are determinative in the context of the final amendments here. In particular, the scope of the final amendments differs substantially from the scope of that proposal. Those cost estimates pertained to a service provider's performance of outsourced functions that meet two elements: (1) those necessary for the adviser to provide its investment advisory services in compliance with the Federal securities laws; and (2) those that, if not performed or performed negligently, would be reasonably likely to cause a material negative impact on the adviser's ability to provide investment advisory services. By contrast, the final amendments here pertain to the protection of customer information in the case of all outsourced functions to all service providers. *See Outsourcing by Investment Advisers*, Release No. 6176 (Oct. 26, 2022) [87 FR 68816, 68821 (Nov. 16, 2022)].

have to perform these tasks. The final amendments adopt a definition of service provider to mean "any person or entity that receives, maintains, processes, or otherwise is permitted access to customer information through its provision of services directly to a covered institution."[918] Many commenters opposed the proposed definition of service provider.[919] These commenters suggested narrower definitions which would exclude a covered institution's affiliates.[920] In addition, one commenter stated that the proposed definition was unrealistically and unnecessarily broad, reaching service providers where there would be few or no marginal benefits to their inclusion and the costs (time, money, personnel, etc.) to covered institutions would be substantial.[921] This commenter suggested that the definition of service provider be limited to persons or entities with permitted access to sensitive customer information only.[922]

We acknowledge that fulfilling the requirements for each of their service providers will impose costs on the covered institutions. However, the potential benefits are also large given the increasing reliance of covered institutions on service providers.[923] Individual customers have no control over a covered institution's decisions to perform activities in-house or to outsource them.

---

918 Final rule 248.30(d)(10).

919 *See, e.g.*, IAA Comment Letter 1; Schulte Comment Letter. The definition of service provider in the final amendments is identical to the definition that was in the proposal. *See supra* section II.A.4.

920 *See* IAA Comment Letter 1 (stating that "the IAA believes that it is neither appropriate nor necessary to treat affiliates that provide services to an affiliated firm through a shared services or similar model as Service Providers"); Schulte Comment Letter ("We believe that the proposed definition of 'service provider' should exclude a Covered Institution's affiliates."); SIFMA Comment Letter 2 ("The associations also recommend that the Commission exclude affiliates of covered institutions from the definition of service providers, as affiliates are part of the same enterprise information/cybersecurity oversight as the covered institutions."); CAI Comment Letter ("The Committee requests that proposed Rule 30(e)(10) be revised to specifically exclude affiliates and other entities under common control with the covered institution.").

921 *See* IAA Comment Letter 1.

922 *See* IAA Comment Letter 1. This commenter also requested, if the proposed written contract requirement were to be kept in the final amendments, that it apply only to those service providers that have physical or virtual access to a covered institution's customer information system.

923 *See supra* section IV.C.3.f.

As such, these customers have little control over who has access to their information. A broad definition of service providers will contribute to safeguard customers' information and will help ensure that customers are notified in the event their sensitive information is compromised, no matter where this information resides. Furthermore, the modifications in the final amendments to require covered institutions to establish, maintain, and enforce written policies and procedures reasonably designed to require oversight, including through due diligence and monitoring, of service providers, instead of requiring written contracts as was proposed,[924] will alleviate the commenters' concerns over the potential inclusion of affiliates. Since affiliates are likely to have policies and procedures similar to those of covered institutions,[925] we expect that both the benefits and the costs of implementing this provision of the requirements will be minimal.

The indirect effects of the final amendments on service providers might also affect the costs borne by covered institutions and, ultimately, their customers. In particular, these indirect effects may generate costs to service providers, which may be passed on (at least partly) to covered institutions and ultimately to covered institutions' customers,[926] or may result in negative competitive effects on service provider industries that then impact the services offered to covered institutions and their customers.[927] The potential indirect effects on service providers that will

---

924 *See* proposed rule 248.30(b)(5)(i).

925 *See* IAA Comment Letter 1 ("Many advisers are structured in a manner that makes it administratively beneficial for them to obtain services from affiliates. These services often are provided by affiliates in a manner established by the organization's policies without the need for formal contracts because the affiliates are typically subject to company-wide policies and standards relating to safeguarding PII. Moreover, the information security policies of affiliates are typically subject to oversight by an organizational component that monitors compliance.") and Schulte Comment Letter ("We note that affiliates are typically included within the scope of a Covered Institution's cybersecurity policies and procedures and would also be covered by an applicable incident response plan.").

926 *See infra* text accompanying footnote 933.

927 *See infra* section IV.E.

result from the final amendments can be divided into three parts.[928] First, entities that meet the definition of service providers will likely take appropriate measures to protect against unauthorized access to or use of customer information to facilitate covered institutions' compliance with the final amendments. We expect that many service providers already take such measures.[929] Hence, we expect that the number of service providers who will modify their business processes for this specific requirement is limited. Such modifications will benefit not only the customers whose information is being better protected and the covered institutions relying on the service providers, but also the service providers themselves, to the extent that the modifications decrease the likelihood of unauthorized access to their customer information systems which could affect their operations or reputation.

Second, covered institutions' policies and procedures will need to be reasonably designed to ensure that service providers take appropriate measures to provide notification of unauthorized access to a customer information system to the covered institutions as soon as possible, but no

---

928 We are unable to quantify the indirect costs associated with these indirect effects that would be incurred by service providers as a result of the final amendments, as the cost range would be too wide to be informative. The uncertainty around these costs is due to a number of factors, including variation in complexity of service provider functions provided to covered institutions, the degree of market concentration across service provider markets (and hence the number of covered institutions a service provider may need to work with to comply with the rule), and variation in current service provider practices. The costs to any single service provider of meeting the burden for any single function for any single covered institution may therefore have substantial variance. For example, in certain cases a few service providers may perform the same function for many covered institutions and hence benefit from economies of scale. By contrast, service providers in less concentrated industries would potentially face higher costs.

929 For example, many states impose some form of requirements regarding the safeguard and the disposal of customer information. *See supra* footnote 603. In addition, the FTC Safeguards Rule requires financial institutions to take reasonable steps to select and retain service providers capable of maintaining appropriate safeguards for customer information and to require those service providers by contract to implement and maintain such safeguards. *See supra* footnote 618 and accompanying text. Hence, we expect that the service providers of private funds subject to the FTC Safeguards Rule already have customer information safeguards in place. This could lower the costs of the service provider provisions of the final amendments for the private funds advisers that are registered with the Commission and that are therefore covered institutions. *See supra* footnote 614 and accompanying text. Furthermore, service providers that are subject to other regimes such as the GDPR or DORA may already have appropriate safeguards in place.